



Price Tag



Bối cảnh (Context)

Hệ thống thương mại điện tử "BuyEverything" đang tổ chức một chương trình dùng thử, tặng mỗi tài khoản mới đăng ký số dư là \$50. Cửa hàng bán các mặt hàng lưu niệm rất rẻ, nhưng có một mặt hàng có tên là "Flag" lại được định giá tận \$9999.

Nhân viên vận hành phàn nàn rằng sổ sách kế toán của họ thỉnh thoảng xuất hiện những con số âm vô lý, nhưng bộ phận kỹ thuật bảo rằng "lỗi nhỏ thôi, không ai mua hàng với số lượng âm đâu".



Mục tiêu (Objective)

- **Nhiệm vụ:** Bằng một cách nào đó, hãy mua được mặt hàng "Flag" trị giá \$9999 khi trong tay bạn chỉ có \$50.
- **Vấn đề / Lỗi hổng:** Lỗi **Business Logic (Logic nghiệp vụ)**. Cụ thể, khi tính tổng tiền (Số lượng * Đơn giá), hệ thống có thể không kiểm tra việc người dùng nhập số lượng là số âm. Nếu bạn mua `-100` cái áo giá `$10`, hệ thống tính tổng tiền là `-$1000`, dẫn đến việc trừ đi số âm tương đương với cộng thêm \$1000 vào tài khoản của bạn.
- **Flag:** Mua thành công đơn hàng "Flag".



Gợi ý (Hints)

- Dùng các công cụ bắt gói tin như Burp Suite để thay đổi số lượng mặt hàng (Quantity) gửi lên server.
- Thử nhập các giá trị âm, hoặc số thập phân, hoặc một số nguyên cực lớn để ép tràn số (Integer Overflow).